

NEXORA TECHNOLOGIES LIMITED

(a fictional company created for a college project)

IT, INFORMATION SECURITY AND ACCEPTABLE USE POLICY

Document No. NTL/HR/POL/009

Version	5.0
Effective Date	2024-10-01
Classification	Internal
Policy Owner	Chief Information Security Officer

Nexora Technologies Limited is a fictional company. This document was created for a college project and is not real HR policy or legal advice.

Uncontrolled when printed. The current version is published on the Nexora People Portal (NPP).

DOCUMENT CONTROL

Document Title	IT, Information Security and Acceptable Use Policy
Document Number	NTL/HR/POL/009
Version	5.0
Effective Date	2024-10-01
Supersedes	Information Security and Acceptable Use Policy version 4.3 dated 1 April 2023
Policy Owner	Chief Information Security Officer
Approved By	Chief Technology Officer and Chief People Officer, noted by the Risk Management Committee
Date of Approval	2024-09-20
Classification	Internal
Review Cycle	Annual, and after any major security incident or change in law
Applicable To	All Employees in Grades L1 to L8, and consultants and contractors with access to Company or client systems

VERSION HISTORY

Version	Date	Description of Change	Prepared / Approved By
3.0	2019-04-01	Consolidated IT acceptable use and information security policies.	Information Security / CTO
4.0	2022-04-01	Remote work and bring-your-own-device provisions added.	Information Security / CTO and CPO
4.3	2023-04-01	Incident reporting timelines aligned with CERT-In directions.	Information Security / CTO and CPO
5.0	2024-10-01	Personal data protection section aligned with the Digital Personal Data Protection Act, 2023; retention schedule added.	Information Security / CTO and CPO

DISTRIBUTION AND ACCESS

Published on the NPP under Policies > Information Security. Every Employee acknowledges this Policy on joining and completes the annual information security training. Printed copies are uncontrolled.

CONTENTS

1. Purpose, Scope and Responsibilities 4

2. Definitions 4

3. Information Classification 4

4. Acceptable Use 5

5. Accounts, Passwords and Access 5

6. Company Devices 6

7. Bring Your Own Device 6

8. E-mail, Collaboration and Internet 7

9. Client Data and Client Environments 7

10. Working Remotely 7

11. Personal Data Protection 8

12. Security Incidents 8

13. Monitoring and Privacy 9

14. Software, Cloud Services and Emerging Technology 9

15. Physical Security 9

16. Compliance and Exceptions 9

17. Secure Development 10

18. Third-Party Access 10

19. Backup and Availability 10

Annexure A: Security Incident Report 11

Annexure B: Enrolling a Personal Device 11

Annexure C: Frequently Asked Questions 11

Annexure D: Quick Reference 12

Annexure E: Privacy Notice for Employees 12

Annexure F: Classification Examples by Function 12

Amendment Circulars 14

 Circular HR/CIR/2025/02: Revised password requirements 14

 Circular HR/CIR/2025/13: Use of generative AI tools 14

1. PURPOSE, SCOPE AND RESPONSIBILITIES

- 1.1 **Purpose.** The Company holds information entrusted to it by clients, Employees and partners. This Policy sets the rules for using the Company's information technology, for protecting information and personal data, and for reporting incidents, so that the Company meets its obligations under client contracts and applicable law and protects the people whose data it holds.
- 1.2 **Scope.** This Policy applies to every Employee, consultant and contractor who uses a Company device, a Company or client system, or a BYOD Device for work, at any location, including at home, at a client site and while travelling.
- 1.3 **Client requirements.** Where a client contract or the client's security policy imposes stricter requirements than this Policy for a project, the stricter requirements apply to that project. The project manager communicates them at onboarding, and they are recorded on the project's security plan.
- 1.4 **Responsibilities.** The Chief Information Security Officer (CISO) owns this Policy and the security programme. The IT Service Desk provides devices, access and first-line support. The Security Operations Centre monitors systems and responds to incidents. The Data Protection Officer oversees compliance with data protection law. Every Employee is responsible for following this Policy and for reporting incidents promptly.

2. DEFINITIONS

- 2.1 **"BYOD Device"** means a mobile phone, tablet or computer owned by an Employee and approved under Section 7 for access to Company e-mail, collaboration tools or systems.
- 2.2 **"Client Data"** means any information, including personal data, provided by or on behalf of a client, or created for a client under a contract, including source code, documents, test data and system credentials.
- 2.3 **"Data Principal"** means the individual to whom personal data relates, including an Employee, a candidate, or a customer of a client.
- 2.4 **"Information Asset"** means any information, in any form, and any device, system, application or account on which information is stored or processed, that is owned by or entrusted to the Company.
- 2.5 **"Multi-Factor Authentication"** (MFA) means the verification of identity by two or more independent factors, such as a password and a code generated on a registered device.
- 2.6 **"Personal Data"** means any data about an individual who is identifiable by or in relation to such data, as defined in the Digital Personal Data Protection Act, 2023.
- 2.7 **"Personal Data Breach"** means any unauthorised processing of Personal Data or accidental disclosure, acquisition, sharing, use, alteration, destruction or loss of access to Personal Data that compromises its confidentiality, integrity or availability.
- 2.8 **"Security Incident"** means any event that compromises or may compromise the confidentiality, integrity or availability of an Information Asset, including a Personal Data Breach, malware infection, phishing compromise, loss or theft of a device, or unauthorised access.
- 2.9 **"Security Operations Centre"** (SOC) means the Company's team that monitors systems 24 hours a day and responds to Security Incidents, reachable at itsd@nexora.example or the security hotline 1800-000-0000 (extension 6).

3. INFORMATION CLASSIFICATION

- 3.1 **Classification levels.** Every Information Asset is classified by its owner at one of four levels, and handled according to Table 1. Documents carry their classification in the header or footer; where no classification is marked, the information is treated as Internal.

Table 1: Classification levels and handling rules

Level	Examples	Storage and sharing	Disposal
Public	Published annual report, press releases, job advertisements	No restriction	No restriction
Internal	Policies on the NPP, organisation charts, internal announcements	Company systems only; may be shared with any Employee	Normal deletion
Confidential	Client Data, contracts, pricing, source code, employee records, unpublished financial information	Approved systems with access limited to those who need it; encrypted when sent outside the Company	Secure deletion; shredding of paper
Restricted	Credentials, encryption keys, medical and POSH records, UPSI, client production data containing Personal Data	Named individuals only; stored in designated vaults or restricted repositories; never sent by e-mail	Secure deletion verified by the IT Service Desk; cross-cut shredding

3.2 Reclassification. Information may be downgraded only by its owner. Client Data retains the classification given by the client or, where none is given, is treated as Confidential.

4. ACCEPTABLE USE

4.1 Business use. Company devices, networks, e-mail and systems are provided for the Company's business. Limited personal use, such as reading news or making a personal online payment, is permitted if it is occasional, does not interfere with work, does not consume significant resources, and does not breach this Policy.

4.2 Prohibited use. Employees shall not use Company Information Assets to:

- (a) access, store or share unlawful, obscene, sexually explicit, hateful or harassing material;
- (b) download or use pirated software, films, music or other content, or infringe any intellectual property;
- (c) mine cryptocurrency, run personal businesses, or engage in gambling;
- (d) disable, bypass or interfere with security controls, including antivirus, endpoint detection, data loss prevention or the virtual private network;
- (e) install software that is not in the approved software catalogue, or connect unapproved hardware;
- (f) store or transfer Company or Client Data in personal e-mail, personal cloud storage or personal messaging applications; or
- (g) share an account, password or one-time code with any other person, including a colleague or a manager.

4.3 No expectation of privacy on Company systems. Information created, stored or sent on Company systems belongs to the Company. Employees should not expect privacy in their use of Company systems, subject to the limits on monitoring in Section 13.

5. ACCOUNTS, PASSWORDS AND ACCESS

5.1 Individual accounts. Each user has a unique account. Actions performed with an account are attributed to its holder. Shared or generic accounts are permitted only where approved by the CISO for a technical need, with a named owner.

5.2 Passwords. Passwords are at least 12 characters long, combine upper and lower case letters, numbers and symbols, are not reused across the last ten passwords, and are changed every 90 days. Passwords are never written down, shared or stored in a browser on a shared computer; the Company's password manager may be used.

5.3 Multi-Factor Authentication. Multi-Factor Authentication is mandatory for e-mail, the virtual private network, the NPP, cloud administration consoles and all client systems that support it. Employees never approve an authentication request they did not initiate, and report any unexpected request to the SOC immediately.

- 5.4 Access on the basis of need.** Access to systems and data is granted on the basis of least privilege and approved by the Information Asset owner. Access is reviewed every quarter by the owner, and removed within one Working Day of a change of role or project and on the Last Day of Service.
- 5.5 Privileged access.** Administrator and production access is granted only to named Employees for a defined need, through a separate privileged account with MFA, and every privileged session is logged. Production access for Client Data requires the client's approval where the contract so requires.

6. COMPANY DEVICES

- 6.1 Standard controls.** Company laptops are issued with full-disk encryption, endpoint detection and response software, the virtual private network client and data loss prevention controls. Screens lock automatically after five minutes of inactivity. Security updates are installed within seven days of release; a device that is not updated within 14 days is blocked from the network until it is.
- 6.2 Removable media.** USB storage devices, memory cards and external drives are blocked on Company laptops. An exception for a specific business need, such as delivering a build to a client on encrypted media, requires the approval of the CISO and is time-limited.
- 6.3 Printing.** Confidential and Restricted documents are printed only on Company printers using secure release with the identity card, and collected immediately. Printing Client Data at home or at a public printing shop is prohibited.
- 6.4 Loss or theft.** The loss or theft of a Company device is reported to the SOC within one hour of discovery, so that the device can be locked and wiped remotely, and to the police as described in the Employee Handbook (NTL/HR/POL/002).

7. BRING YOUR OWN DEVICE

- 7.1 What may be used.** An Employee may use a personal device for work only within the permissions for the Employee's Grade in Table 2, and only after enrolment under Clause 7.2. No personal device may be used for any project whose client prohibits it.

Table 2: Permitted personal devices by Grade

Grade	Personal mobile phone	Personal tablet	Personal laptop or computer
L1	E-mail, chat and calendar through the managed work profile	Not permitted	Not permitted
L2	E-mail, chat and calendar through the managed work profile	Not permitted	Not permitted
L3	E-mail, chat and calendar through the managed work profile	Not permitted	Not permitted
L4	E-mail, chat and calendar through the managed work profile	Not permitted	Not permitted
L5	E-mail, chat, calendar and the NPP through the managed work profile	Same as mobile phone	Not permitted
L6	E-mail, chat, calendar and the NPP through the managed work profile	Same as mobile phone	Not permitted
L7	E-mail, chat, calendar and the NPP through the managed work profile	Same as mobile phone	Only through the Company virtual desktop, with no local storage
L8	E-mail, chat, calendar and the NPP through the managed work profile	Same as mobile phone	Only through the Company virtual desktop, with no local storage

Client Data may not be stored on or downloaded to any personal device in any Grade.

- 7.2 Enrolment.** A personal device is enrolled in the Company's mobile device management solution within seven days of the Employee first accessing Company e-mail on it, following the steps in Annexure B. The solution creates a separate, encrypted work profile. Devices that are not enrolled within seven days are blocked.

- 7.3 What the Company can and cannot do.** The Company can see the device model, operating system version, and whether the device meets security requirements, and can remove the work profile and its data remotely. The Company cannot see or access the Employee's personal apps, photos, messages, browsing or location, and does not wipe the personal part of the device.
- 7.4 Requirements.** A BYOD Device must run a supported operating system version, have a screen lock, not be rooted or jailbroken, and be updated within 30 days of a security update. Loss of a BYOD Device is reported to the SOC within one hour so that the work profile can be removed.
- 7.5 No reimbursement.** The Company does not reimburse the purchase or repair of a personal device. Communication costs are covered by the communication allowance or internet reimbursement described in the Compensation and Benefits Policy (NTL/HR/POL/005) and the Employee Handbook (NTL/HR/POL/002).

8. E-MAIL, COLLABORATION AND INTERNET

- 8.1 Phishing.** Employees are cautious with unexpected e-mails and messages, particularly those that ask for credentials, payment, urgent action or the opening of attachments. Suspicious e-mails are reported using the report button in the e-mail client. The Company runs simulated phishing exercises; an Employee who fails repeatedly is assigned additional training.
- 8.2 Sending information outside the Company.** Confidential information sent outside the Company is encrypted using the Company's secure mail or file transfer tool. Automatic forwarding of Company e-mail to any external address is blocked. Restricted information is never sent by e-mail.
- 8.3 Collaboration tools.** Only the Company's approved chat, video conferencing and file-sharing tools are used for work. Client-specific tools may be used where the client requires, through accounts provided by the client. Recording of meetings is governed by the Code of Conduct and Ethics (NTL/HR/POL/004).
- 8.4 Internet access.** Web filtering blocks categories of websites that present security or legal risk, including malware, gambling, adult content and unapproved file-sharing sites. An Employee who needs access to a blocked site for work requests it through the IT Service Desk.

9. CLIENT DATA AND CLIENT ENVIRONMENTS

- 9.1 Use only for the client.** Client Data is used only for the project for which it was provided, is accessed only by Employees assigned to that project, and is never copied to Company systems outside the project environment, to another client's environment, or to any personal device or account.
- 9.2 Offshore development centres.** Projects that require it are delivered from a secured offshore development centre with badge-controlled access limited to project members. In such areas, personal mobile phones, cameras and storage devices are deposited at the entrance, printing is disabled, and a clean desk is maintained at all times.
- 9.3 Test data.** Production data containing Personal Data is not used for development or testing unless it has been masked or anonymised in accordance with the project's security plan, or the client has approved its use in writing with safeguards.
- 9.4 End of project.** At the end of a project, Client Data is returned to the client or securely deleted in accordance with the contract, and the project manager records the certificate of deletion. Access to client systems is removed within one Working Day.

10. WORKING REMOTELY

- 10.1 Secure connection.** When working away from a Company office, Employees connect to Company and client systems only through the virtual private network or the Company virtual desktop. Home Wi-Fi uses WPA2 or stronger encryption with a changed default password. Public Wi-Fi may be used only with the virtual private network connected.
- 10.2 Surroundings.** Employees work where screens cannot be overlooked and calls cannot be overheard by others, use a privacy screen in public places, and do not leave a device unattended in a vehicle or public

place.

- 10.3 Working from abroad.** Access to Company systems from outside India requires the prior approval described in the Employee Handbook (NTL/HR/POL/002), because Client Data may be subject to restrictions on transfer outside India. Access from a country on the Company's restricted list is blocked.

11. PERSONAL DATA PROTECTION

- 11.1 Roles of the Company.** For the Personal Data of its Employees and candidates, the Company is a data fiduciary under the Digital Personal Data Protection Act, 2023. For Personal Data in Client Data, the Company usually processes it on behalf of the client, and follows the client's instructions and the contract.
- 11.2 Principles.** The Company processes Personal Data only for a lawful purpose, on the basis of consent or a legitimate use permitted by law, with a clear notice to the Data Principal; collects only the data needed for the purpose; keeps it accurate; retains it only as long as needed under Table 3; and protects it with reasonable security safeguards as required by the Act.
- 11.3 Rights of Data Principals.** Employees and candidates may exercise the rights given to Data Principals by the Act, including the right to access information about their Personal Data, to correction and erasure, to grievance redressal, and to nominate another person to exercise their rights in the event of death or incapacity, by writing to the Data Protection Officer at dpo@nexora.example. The Data Protection Officer responds within the time required by law and in any case within 30 days.
- 11.4 Personal Data Breach.** In the event of a Personal Data Breach involving Personal Data for which the Company is the data fiduciary, the Company informs the Data Protection Board of India and each affected Data Principal in the form and manner prescribed under the Act. Where the Company processes the data for a client, it informs the client within the time required by the contract so that the client can meet its obligations.
- 11.5 Retention.** Personal Data held by the Company about Employees and candidates is retained for the periods in Table 3, and then deleted or anonymised, unless a longer period is required by law or for a pending legal proceeding.

Table 3: Retention schedule for employee-related records

Record	Retention period	Basis
Employee personnel file, contracts and letters	8 years after the Last Day of Service	Limitation periods and statutory inspection
Payroll, tax and provident fund records	8 years after the end of the financial year	Tax and labour law record-keeping
Medical certificates and leave supporting documents	3 years after the end of the Leave Year in which submitted	Purpose of verification completed
Internal Committee and disciplinary files	8 years after closure	Possible appeals and litigation
Unsuccessful candidates' applications	12 months after the decision	Possible reconsideration, with consent
Access logs and security logs	1 year, or 180 days rolling as a minimum	Legal direction on log retention
CCTV footage	90 days	Security of premises

12. SECURITY INCIDENTS

- 12.1 Report immediately.** Every Employee reports a known or suspected Security Incident to the SOC immediately and in any case within one hour of becoming aware of it, by telephone on the security hotline or by e-mail to itsd@nexora.example. Examples include clicking a phishing link, sending Client Data to the wrong recipient, losing a device, noticing unusual system behaviour, or finding a colleague's password written down.
- 12.2 What not to do.** Employees do not try to investigate an incident themselves, delete evidence, contact the suspected source, or discuss the incident outside those who need to know. They follow the SOC's instructions, which may include disconnecting a device from the network without switching it off.

- 12.3 Reporting to authorities and clients.** The SOC assesses each incident, and the Company reports specified cyber security incidents to CERT-In within six hours of noticing them, as directed under the Information Technology Act, 2000. Clients are notified of incidents affecting their data within the time required by the contract.
- 12.4 No blame for honest reporting.** An Employee who reports an incident promptly, including one caused by the Employee's own honest mistake, is not disciplined for the mistake. Concealing an incident, or delaying a report, is misconduct under the Code of Conduct and Ethics (NTL/HR/POL/004).

13. MONITORING AND PRIVACY

- 13.1 What is monitored.** To protect Information Assets and meet legal and contractual obligations, the Company monitors the use of Company systems, including network traffic, e-mail for malware and data loss, access to systems, and the security status of devices. CCTV is used in common areas of offices, and never in washrooms, changing rooms, lactation rooms or rest rooms.
- 13.2 Limits.** Monitoring is proportionate and automated. The content of an individual Employee's e-mail, chat or files is reviewed only for a specific investigation of a Security Incident or misconduct, with the written approval of the CISO and the Chief People Officer, and the review is logged. Personal apps and data on a BYOD Device are never monitored.
- 13.3 Use of monitoring data.** Monitoring data is used only for security, compliance and investigations. It is not used to measure productivity or to rank Employees.

14. SOFTWARE, CLOUD SERVICES AND EMERGING TECHNOLOGY

- 14.1 Approved software.** Only software in the approved software catalogue, available from the software centre on the Company laptop, may be installed. A request for new software is reviewed by Information Security for licensing and security within ten Working Days.
- 14.2 Cloud services.** A cloud service, including any website or application that stores or processes Company or Client Data, may be used for work only if it is in the approved catalogue. Any other cloud service is prohibited for Company or Client Data, even if it is free, and even for a trial.
- 14.3 Open-source software.** Open-source components in Company or client software are used only under licences approved by the Legal department, and are recorded in the project's software bill of materials. Components with known critical vulnerabilities are not used.

15. PHYSICAL SECURITY

- 15.1 Access to premises.** Employees badge in individually at every access point and do not allow others to follow them through a controlled door. Visitors are registered at reception, wear a visitor badge and are escorted at all times.
- 15.2 Clean desk.** At the end of the day, and when leaving the desk for an extended period, Employees clear Confidential and Restricted documents from the desk, lock the screen, and lock away devices. Whiteboards in meeting rooms are wiped after client discussions.
- 15.3 Disposal.** Paper containing Confidential or Restricted information is placed in the locked shredding bins. Devices and storage media are returned to the IT Service Desk for certified destruction and are never sold, given away or disposed of by the Employee.

16. COMPLIANCE AND EXCEPTIONS

- 16.1 Training and acknowledgement.** Every Employee completes the information security and data privacy training on joining and each year, as described in the Employee Handbook (NTL/HR/POL/002), and acknowledges this Policy on the NPP.
- 16.2 Exceptions.** An exception to this Policy is requested through the IT Service Desk, assessed by Information Security, approved by the CISO, recorded in the exceptions register with an expiry date not exceeding 12 months, and reviewed at expiry.

- 16.3 Breach of this Policy.** A breach of this Policy may result in the withdrawal of access and disciplinary action under the Code of Conduct and Ethics (NTL/HR/POL/004). A deliberate disclosure of Client Data or Restricted information is gross misconduct and may also be an offence under the Information Technology Act, 2000.

17. SECURE DEVELOPMENT

- 17.1 Secure coding.** Employees who write code for the Company or its clients follow the secure coding standard published by Information Security, which addresses input validation, authentication, session management, error handling and the protection of secrets. Code is reviewed by a second developer before it is merged into a release branch.
- 17.2 Secrets in code.** Passwords, API keys, tokens and certificates are never written into source code, configuration files committed to a repository, tickets or chat. They are stored in the approved secrets vault. Automated scanning checks every repository for secrets, and any secret found is treated as compromised and rotated immediately.
- 17.3 Repositories.** Company and Client source code is stored only in repositories approved for the project. Copying code to a personal repository, a public code-hosting account or a personal device is prohibited, including code written by the Employee.
- 17.4 Testing and vulnerabilities.** Applications are tested for security vulnerabilities before release, as required by the project's security plan. Critical and high-severity vulnerabilities are fixed before release or accepted in writing by the client and the CISO with a remediation date.

18. THIRD-PARTY ACCESS

- 18.1 Vendors and contractors.** A vendor or contractor is given access to Company systems or data only under a contract that includes confidentiality, security and data protection obligations, after a security assessment by Information Security proportionate to the access requested.
- 18.2 Sponsorship.** Every third-party account has an Employee sponsor, who approves the access, ensures that it is used only for the contracted work, and requests its removal when the work ends. Third-party accounts expire automatically after 90 days unless renewed by the sponsor.
- 18.3 Sharing Personal Data with vendors.** Personal Data of Employees is shared with a vendor, such as an insurer or a background verification agency, only where needed for a stated purpose, under a contract that restricts the vendor's use of the data to that purpose and requires its deletion afterwards.

19. BACKUP AND AVAILABILITY

- 19.1 Backups.** Company systems and data are backed up centrally by the IT function according to the backup schedule for each system, and restoration is tested every quarter. Employees save work on approved Company storage, which is backed up, rather than only on the laptop.
- 19.2 Business continuity.** Critical systems and client services have continuity plans that are tested at least once a year. Employees named in a continuity plan know their role and keep the contact details of their team up to date on the NPP.

ANNEXURE A: SECURITY INCIDENT REPORT

Report by telephone first where the incident is urgent. The information below is then recorded with the SOC, which assigns an incident number.

Form IS-01: Security Incident report

Name, Employee ID, project and contact number	
Date and time the incident happened and when it was discovered	
What happened (for example, e-mail sent to wrong recipient, device lost, suspicious link clicked)	
Information or systems involved and their classification	
Whether Personal Data or Client Data may be affected	
Actions already taken	

ANNEXURE B: ENROLLING A PERSONAL DEVICE

- B.1 Steps.** Install the Company's device management application from the official app store; sign in with the Company account and approve the MFA request; accept the privacy notice, which explains what the Company can and cannot see under Clause 7.3; allow the application to create the work profile; and install Company e-mail and chat inside the work profile only.
- B.2 Removing a device.** An Employee may remove the work profile at any time from the application, which ends access to Company e-mail on the device. The work profile is removed automatically on the Last Day of Service, as described in the Separation and Exit Policy (NTL/HR/POL/008).

ANNEXURE C: FREQUENTLY ASKED QUESTIONS

- C.1 I am an L3. Can I use my own laptop at home to check a document?** No. Personal laptops and computers are permitted only for Grades L7 and L8, and only through the Company virtual desktop, under Table 2. Employees in Grades L1 to L6 use the Company laptop.
- C.2 I sent a client spreadsheet to the wrong external e-mail address. What should I do?** Report it to the SOC immediately, within one hour, under Clause 12.1. Do not try to recall or contact the recipient yourself unless the SOC asks you to. Prompt reporting of an honest mistake is not penalised under Clause 12.4.
- C.3 Can my manager read my chat messages?** No. Managers have no access to Employees' messages. Content is reviewed only for a specific investigation, with the approval of the CISO and the Chief People Officer, under Clause 13.2.
- C.4 Can the Company wipe my personal phone?** No. The Company can remove only the work profile and its data, not your personal apps, photos or files, under Clause 7.3.
- C.5 A free online tool converts files quickly. Can I use it for a client document?** No. A cloud service that is not in the approved catalogue is prohibited for Company or Client Data, even if free, under Clause 14.2.
- C.6 I found an API key in a colleague's code in the repository. What should I do?** Report it to the SOC. A secret found in a repository is treated as compromised and rotated immediately under Clause 17.2. Do not use the key, and do not post it in a chat or ticket.
- C.7 A vendor's engineer asks me to share my login so that they can fix an issue quickly. Can I?** No. Accounts are never shared under Clause 4.2. The vendor's access is requested through its Employee sponsor under Clause 18.2, and the IT Service Desk can arrange supervised temporary access if it is urgent.

ANNEXURE D: QUICK REFERENCE

Table 4: Everyday security at a glance

Do	Do not
Lock your screen whenever you leave your desk	Share your password or one-time code with anyone
Report suspicious e-mails with the report button	Click links in unexpected messages asking you to sign in
Use the virtual private network outside the office	Copy Client Data to a personal device or account
Report a lost device within one hour	Install software from outside the approved catalogue
Use secure mail for Confidential information sent outside	Print client documents at home
Check the classification before sharing a document	Paste Company or client information into unapproved online tools

ANNEXURE E: PRIVACY NOTICE FOR EMPLOYEES

This notice summarises how the Company, as data fiduciary, processes the Personal Data of Employees. It is provided under Clause 11.2 and does not reduce any right under law.

- E.1 What we collect.** Identity and contact details; identity numbers needed for tax and provident fund; bank details; education and employment history and background verification results; performance, attendance, leave and payroll records; photographs for identity cards; system access and security logs; and, where the Employee provides them, medical documents, disability information and details of dependants for insurance.
- E.2 Why we use it.** To recruit and employ Employees; to pay salaries and meet tax, provident fund and other legal obligations; to provide insurance and benefits; to manage performance, leave and attendance; to protect Information Assets and premises; to meet client requirements such as background checks; and to handle grievances, complaints and legal proceedings.
- E.3 Who we share it with.** Personal Data is shared only as needed with: government authorities where required by law; insurers and the third-party administrator; background verification agencies, with consent; the payroll and HR system providers, under contract; banks for salary payment; and a client, limited to what the client contract requires, such as a name and a background check confirmation. The Company does not sell Personal Data.
- E.4 How long we keep it.** For the periods in Table 3, after which it is deleted or anonymised.
- E.5 Your rights and contact.** An Employee may request access to, correction of, or erasure of Personal Data, and may raise a grievance with the Data Protection Officer at dpo@nexora.example, as described in Clause 11.3. If a grievance is not resolved, the Employee may approach the Data Protection Board of India in the manner provided by law.

ANNEXURE F: CLASSIFICATION EXAMPLES BY FUNCTION

Table 5: Typical classification of common information

Function	Information	Classification
HR	Organisation chart and policy documents on the NPP	Internal
HR	Individual salary, ratings and personnel files	Confidential
HR	Medical certificates, disability records and Internal Committee files	Restricted
Finance	Published quarterly results after release	Public
Finance	Unpublished quarterly results and forecasts	Restricted
Sales	Proposals, pricing and rate cards	Confidential
Delivery	Client source code, designs and test results	Confidential, or as classified by the client
Delivery	Client production data containing Personal Data	Restricted
IT	Network diagrams and system configurations	Confidential
IT	Administrator passwords, keys and certificates	Restricted
Marketing	Approved case studies naming a client with consent	Public

AMENDMENT CIRCULARS

The circulars below amend this Policy with the approval of the CISO and the Chief Technology Officer. Each prevails over the clause it amends from its effective date; the body of the Policy is reproduced unedited.

CIRCULAR NO. HR/CIR/2025/02

Circular No.	HR/CIR/2025/02
Date of Issue	2025-02-10
Effective From	2025-03-01
Subject	Revised password requirements
Amends	Clause 5.2
Issued By	Chief Information Security Officer

In line with current guidance that frequent forced changes lead to weaker passwords, with effect from 1 March 2025:

- (a) passwords are at least 14 characters long, and a passphrase of several words is encouraged;
- (b) the requirement to change passwords every 90 days under Clause 5.2 is withdrawn, and a password is changed only when there is any indication that it may have been compromised, or when the SOC requires it; and
- (c) passwords are checked automatically against lists of known breached passwords, which may not be used.

All other requirements of Clause 5.2 and of MFA under Clause 5.3 continue to apply.

CIRCULAR NO. HR/CIR/2025/13

Circular No.	HR/CIR/2025/13
Date of Issue	2025-12-08
Effective From	2025-12-15
Subject	Use of generative AI tools
Amends	Clause 14.2
Issued By	Chief Information Security Officer and Chief Technology Officer

This Circular clarifies how Clause 14.2 applies to generative AI tools, such as AI chat assistants and code assistants, with effect from 15 December 2025.

- (a) Company and Client Data classified as Internal, Confidential or Restricted must not be entered into any public or consumer generative AI tool, including free versions of AI chat assistants, whether through a Company or a personal device.
- (b) The Company's approved AI assistant, available from the software centre, may be used with Internal and Confidential Company information. It may be used with Client Data only where the client has approved its use in writing and the project's security plan records the approval.
- (c) Output from any AI tool is reviewed by the Employee for accuracy, security and licensing before use, and the Employee remains responsible for it.
- (d) Entering Client Data into an unapproved AI tool is treated as a disclosure of Client Data under Clause 16.3.